



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



SANDWORM_MODE and AI Toolchain Supply-Chain Exposure

Threat Report

Classification	TLP:CLEAR
Published	2026-08-03
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | SANDWORM_MODE and AI Toolchain Supply-Chain Exposure - Threat Report

Published: 2026-08-03 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Activity Overview
5. Affected Sectors and Exposure
6. Aviation and Aerospace Sector Impact
7. Tactics, Techniques, and Procedures
8. Infrastructure and Indicators
9. Detection Engineering
 - 9.1. Detection Summary
10. Threat Hunting
 - 10.1. Hunt Hypothesis
11. Risk Assessment
12. Recommended Actions
13. References

SANDWORM_MODE and AI Toolchain Supply-Chain Exposure

1. Executive Summary

CrowdStrike reporting highlights SANDWORM_MODE as a useful model for analyzing compromise paths through modern AI and software toolchains. Even when details are campaign-specific, the defender lesson is broader: AI CI/CD, model pipelines, tokens, repositories, and build agents need the same detection coverage as traditional production systems.

Analyst judgment: the reporting is useful for near-term defensive review because it maps to active exposure areas: identity abuse, edge/infrastructure access, supply-chain dependencies, AI/software pipeline trust, industrial systems, or sector-specific operations. This report is not an attribution declaration; it translates public reporting into defender actions.

2. Intelligence Requirements

Question	Current Answer	Confidence
What should defenders review today?	Review AI toolchain, CI/CD, repository, and privileged token telemetry.	Medium
Which environments are most exposed?	AI-enabled engineering, aerospace software, defense manufacturing, and enterprise development environments	Medium
What telemetry is needed?	Identity, endpoint, proxy, DNS, cloud audit, and vulnerability-management data	High

3. Source Review & Confidence

Source	Contribution	Confidence
CrowdStrike: Detecting SANDWORM_MODE and AI Toolchain Supply Chain Attacks	Primary reporting/context	High
CrowdStrike Blog Index	Publication-date corroboration	Medium
MITRE ATT&CK Enterprise Matrix	Technique mapping reference	High

4. Threat Activity Overview

Treat AI and software-supply-chain systems as production attack surface. Monitor for unexpected model/package pulls, token use outside normal automation, new CI runners, unsanctioned scripts, and suspicious network egress from build systems.

5. Affected Sectors and Exposure

Sector / Segment	Exposure Path	Defender Relevance
Enterprise IT	Identity systems, endpoints, edge devices, SaaS	Common initial-access and lateral-movement path
Critical infrastructure	OT/ICS connectivity, remote access, managed services	Increased operational impact from service disruption
Aviation / Aerospace	Airlines, airports, aerospace manufacturing, satellite/space systems, MRO, and aviation supply chain	Validate third-party dependencies and operational segmentation

6. Aviation and Aerospace Sector Impact

Segment	Operational Relevance	Defender Action
Airlines and airports	Reservation, crew, baggage, network, and supplier systems can turn IT compromise into operational disruption	Prioritize identity hardening, service-provider assurance, and incident communications playbooks
Aerospace/defense manufacturing	Sensitive engineering data, build pipelines, and suppliers create espionage and supply-chain exposure	Monitor engineering repositories, contractor access, and privileged tooling
Satellite/space systems	Ground-segment, SATCOM, telemetry, and vendor appliances may be shared across customers	Validate management-plane isolation and vendor patch status

7. Tactics, Techniques, and Procedures

Tactic / Phase	Observed Technique	Evidence
Initial Access	Phishing, valid accounts, exploit public-facing application, or supply-chain trust abuse	Patterns repeatedly highlighted in cited reporting
Discovery	Network, cloud, repository, or operational process discovery	Defenders should monitor enumeration after first access
Collection / Impact	Data theft, service disruption, tooling compromise, or extortion	Reported risks affect confidentiality and operational continuity

8. Infrastructure and Indicators

Indicator / Infrastructure	Type	Operational Use
No stable IOC set in public reporting	Source limitation	Focus on behavior, asset exposure, and control validation
Newly created admin sessions	Behavioral signal	Prioritize identity and audit-log review
Unexpected build/toolchain activity	Behavioral signal	Relevant for AI/software supply-chain and engineering environments

9. Detection Engineering

9.1. Detection Summary

Signal	Telemetry Source	Analytic Goal
First-seen external remote access from uncommon geography	VPN / IdP / SSO	Identify identity-led access attempts
Suspicious scripting or toolchain invocation	EDR / developer platform logs	Surface execution in build, AI, or engineering systems
Unusual outbound connections from operational network zones	Firewall / DNS / proxy	Detect command-and-control or data staging behavior

title: Daily Threat Review Suspicious Toolchain Or Remote Access Activity

```

id: lbc-tr-2026-901-daily-threat-signal
status: experimental
description: Behavior-focused analytic for the 2026-08-03 Lost Boys Cyber daily threat report.
logsource:
  category: process_creation
  product: windows
detection:
  selection_tools:
    Image|endswith:
      - '\powershell.exe'
      - '\pwsh.exe'
      - '\python.exe'
      - '\node.exe'
      - '\git.exe'
  selection_suspicious:
    CommandLine|contains:
      - 'Invoke-WebRequest'
      - 'curl '
      - 'wget '
      - 'token'
      - 'credential'
      - 'pipeline'
  condition: selection_tools and selection_suspicious
falsepositives:
  - Approved automation and engineering activity
level: medium

```

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where FileName in~ ("powershell.exe", "pwsh.exe", "python.exe", "node.exe", "git.exe")
| where ProcessCommandLine has_any ("Invoke-WebRequest", "curl ", "wget ", "token", "credential",
"pipeline")
| summarize Events=count(), Devices=dcount(DeviceName), Accounts=dcount(InitiatingProcessAccountName)
by FileName, InitiatingProcessAccountName, bin(Timestamp, 1d)
| where Events > 5

```

10. Threat Hunting

10.1. Hunt Hypothesis

If this activity is present in the environment, analysts should see identity anomalies, unusual tooling in administrative or engineering contexts, and atypical network egress from sensitive systems.

```

DeviceNetworkEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("powershell.exe", "python.exe", "node.exe", "git.exe",
"java.exe")
| where RemoteUrl !endswith ".microsoft.com" and RemoteUrl !endswith ".windows.net"
| summarize Connections=count(), RemoteHosts=dcount(RemoteUrl) by DeviceName,
InitiatingProcessFileName, bin(Timestamp, 1d)
| where Connections > 20

```

```

SigninLogs
| where TimeGenerated > ago(14d)
| where ResultType == 0
| summarize FirstSeen=min(TimeGenerated), Countries=dcount(Location), Apps=dcount(AppDisplayName) by
UserPrincipalName, IPAddress
| where Countries > 1 or Apps > 5

```

11. Risk Assessment

Dimension	Assessment	Notes
Likelihood	Medium	Based on public reporting and broad

		applicability to common enterprise controls
Impact	Medium to High	Higher for operationally constrained aviation/aerospace and critical-infrastructure environments
Confidence	Medium	Source depth is public; no private telemetry was available in this run

12. Recommended Actions

Priority	Owner	Action
Critical	SOC	Convert the included hunts into environment-specific saved queries and review hits
High	Vulnerability / IT Ops	Validate exposed edge, remote access, and managed-service dependencies
High	Aviation / OT Security	Confirm segmentation between business IT, operational aviation systems, engineering, and vendor access
Medium	GRC	Add cited reporting to supplier-risk and executive-awareness briefings

13. References

- [1] CrowdStrike: Detecting SANDWORM_MODE and AI Toolchain Supply Chain Attacks: <https://www.crowdstrike.com/en-us/blog/denying-the-worm-sandworm-mode-and-ai-toolchain-supply-chain-attacks/>
- [2] CrowdStrike Blog Index: <https://www.crowdstrike.com/en-us/blog/>
- [3] MITRE ATT&CK Enterprise Matrix: <https://attack.mitre.org/>